



TryHackBox

ترجمه شده توسط کاوه

اردیبهشت ماه 1404

وایرشارک برای رد تیمرها

از پایه تا پیشرفته
تکنیک‌های تحلیل شبکه

توسط کاوه

اخطار: این کتاب صرفاً به منظور آموزش و پژوهش نوشته شده است. استفاده بدون مجوز از سیستم‌ها بدون اجازه قانونی، غیرمجاز و غیرقانونی است. همیشه تست‌ها را در محیطی کنترل‌شده و قانونی انجام دهید.

وایرشارک برای رد تیمرها

عنوان :

کاوه

مترجم :

<https://www.x.com/kavehxnet>

ارتباط با نویسنده :

<https://t.me/KavehAPT>

کانال شخصی بنده در تلگرام

:

<https://t.me/TryHackBox>

کانال آموزش ما در تلگرام:

اردیبهشت ماه 1404

تاریخ انتشار :

به جهل اندرون، خویشتن خوار شود

به دانش توان ساختن شهر و دیار

این کتابچه صرفاً جنبه آموزشی دارد و در راستای ارتقای فرهنگ و دانش امنیت سایبری تمامی علاقه مندان این حوزه به صورت کاملاً رایگان تهیه و انتشار یافته است؛ لذا هرگونه تکثیر جهت استفاده تجاری ممنوع است؛ هرگونه توزیع و تکثیر از این اثر با ذکر نام نویسنده و منبع آن بلامانع خواهد بود. این جزوه ممکن است دارای اشکالت نوشتاری و فنی جزئی باشد که از نظر تهیه کننده مغفول مانده باشد؛ لذا از شما خواننده فهیم در خواست میشود از طریق تویتر اشکالات، انتقادات و پیشنهادات خود را در جهت تکمیل این کتابچه عملی اقدام فرمایید. خواننده گرامی برای تهیه این اثر زمان و انرژی زیادی صرف شده است و در راستای ارتقاء دانش علمی و فرهنگ امنیت سایبری به صورت رایگان انتشار یافته، هزینه استفاده از این اثر خواندن فاتحه برای خواهرم خواهد بود. در صورتی که این اثر برای شما مفید بود به منظور حمایت از نویسنده جهت ارائه نسخه های جدیدتر می توانید به هر میزان مبلغ دلخواه حمایت کنید:

<https://daramet.com/TryHackBox>

گیت هاب ما :

<https://github.com/TryHackBox>

i.	فصل ۱ – مقدمه‌ای بر وایرشارک (Wireshark)
ii.	وایرشارک چیست؟
iii.	چرا از وایرشارک استفاده کنیم؟
iv.	ارتباط با Red Team
v.	فصل ۲ – پایه‌های وایرشارک: درک ترافیک شبکه
vi.	مبانی کپچر کردن بسته‌های شبکه (Packet Capturing)
vii.	فیلترها و گزینه‌های نمایش
viii.	قوانین رنگ‌بندی (Coloring Rules)
ix.	مرتب‌سازی و گروه‌بندی
x.	رمزگشایی پروتکل‌ها (TCP, UDP, HTTP و غیره)
xi.	فصل ۳ – تکنیک‌های متوسط: تحلیل ترافیک برای شناسایی (Reconnaissance)
xii.	شناسایی دستگاه‌ها و سرویس‌های شبکه
xiii.	استخراج اطلاعات ورود (مانند نام کاربری و رمز عبور) از پروتکل‌های بدون رمزنگاری
xiv.	رسم نقشه توپولوژی شبکه از طریق تحلیل بسته‌ها
xv.	اتوماتیک کردن کارها با TShark
xvi.	فصل ۴ – تکنیک‌های پیشرفته Red Team با وایرشارک
xvii.	استخراج داده از جلسه‌های SMB
xviii.	تحلیل معکوس ارتباطات C2 (Command and Control)
xix.	دور زدن امنیت شبکه با استفاده از بسته‌های (Fragmented Packets)

فصل ۱ – مقدمه‌ای بر وایرشارک (Wireshark)

وایرشارک (Wireshark) معروف‌ترین نرم‌افزار تحلیل پروتکل شبکه در جهان است. این ابزار چندسکویی (cross-platform) بوده، دارای رابط گرافیکی و همچنین رابط خط فرمان است و از انواع مختلفی از پروتکل‌ها پشتیبانی می‌کند. این نرم‌افزار به‌خوبی برای تحلیل شبکه و ترافیک شبکه بهینه‌سازی شده و از الگوی "جاسوسی (sniffing)" پیروی می‌کند.

وایرشارک ترافیک شبکه را از شبکه‌های Ethernet و IEEE 802.11 جمع‌آوری می‌کند و داده‌های جمع‌آوری شده را در قالب یک لیست "بسته‌های داده" چندرنگی نمایش می‌دهد که این امکان بر اساس ضبط‌های جامع پروتکل‌ها فراهم شده است. با این ویژگی‌ها، وایرشارک به یک ابزار ساده اما پیچیده تبدیل شده است که قادر به انجام وظایف ساده تا پیشرفته است. با این حال، گستردگی قابلیت‌ها و تنوع گزینه‌های آن ممکن است برای کاربرانی که برای اولین بار با ویژگی‌های پیچیده و پروتکل محور آن مواجه می‌شوند، دلهره آور و طاقت فرسا باشد. بنابراین، هدف این فصل ارائه راهنمای جامعی درباره ویژگی‌ها و کاربردهای برجسته وایرشارک، به ویژه رابط گرافیکی و خط فرمان آن است.

این فصل بر روی نحوه استفاده تمرکز دارد و ابزارهای "unpackaged" که پایه و اساس وایرشارک هستند و با آن همزیستی دارند را برجسته می‌سازد. این راهنما به چهار بخش مجزا اما به یک اندازه مهم تقسیم شده است. در بخش اول، برنامه وایرشارک مورد توجه قرار می‌گیرد. تکنیک‌های پایه‌ای استفاده مورد بحث قرار می‌گیرند، از جمله نحوه دریافت بسته‌ها با استفاده از ترافیک شبکه بلادرنگ. همچنین، رمزگشایی ساختار شبکه‌های Wi-Fi و نحوه ضبط آن‌ها در یک فایل نیز مستند شده است. این اصول اولیه به طور کلی به کاربران اجازه می‌دهد تا بدون هیچ مشکلی اقدام به ضبط کنند. اما برای ادامه کار به صورت کارآمد، ابزارهایی برای تنظیم فیلترهای ضبط جهت پیش‌گزینش ترافیک خاص مورد نیاز است. هر دو نوع ابزار فیلتر کردن مبتنی بر رابط گرافیکی و خط فرمان پشتیبانی می‌شوند. بخش سوم عملیات پیشرفته ضبط را تعیین می‌کند که مستقیماً از طریق نرم‌افزار و با استفاده از پارامترهای به کار رفته در آزمایش‌های اصلی برای تغییرات محتوای پروتکل شبکه به دست می‌آیند. در مورد پروتکل‌های شبکه، بخش آخر پوشش عمیقی از انواع پروتکل‌های مورد نیاز برای دانش ویرشک ارائه می‌دهد.

+ وایرشارک چیست؟

وایرشارک ابزاری قدرتمند و کاربرپسند برای تحلیل شبکه‌ها است. معمولاً تحلیل شبکه با بررسی ترافیک از طریق پورت آینه‌ای سوئیچ یا هاب انجام می‌شود، یا با ضبط ترافیک با استفاده از پورت TAP یا SPAN برای دریافت کپی تمام ترافیک ورودی و خروجی از یک پورت خاص یا چندین پورت. به عنوان یک تحلیلگر بسته‌های

شبکه، وایرشارک ابزار مناسبی برای ارائه تمام اطلاعات اولیه درباره محتوای ترافیک جاری در شبکه شما می‌باشد.

وایرشارک همچنین دارای مجموعه‌ای از ویژگی‌های پیشرفته است که می‌توانند در صورت نیاز تحلیل‌های تکمیلی ارائه دهند. این ابزار روشی ساده برای ایجاد فیلترها فراهم می‌کند و همچنین دارای قابلیت‌های آماری پایه و امکان انجام تغییرات در بسته‌ها می‌باشد. علاوه بر این، وایرشارک را می‌توان با ابزارهای دیگر تکمیل کرد تا در تحلیل‌های آماری دقیق‌تر یا اطلاعات خاصی که توسط ابزارهای بررسی بسته‌ها به اشتراک گذاشته نمی‌شوند، کمک کند.

جامعه کاربری پشتیبان وایرشارک بسیار فعال است. این ویژگی به توسعه‌دهندگان امکان می‌دهد نسخه‌های جدید و به‌روزرسانی‌شده‌ای ارائه دهند که با طیف گسترده‌ای از پروتکل‌های ارتباطی کار کنند و همچنین کتابخانه‌های پروتکل به‌روز را تولید نمایند. این جامعه کاربری همچنین هنگام عیب‌یابی رویدادهای خاص در شبکه می‌تواند کمک کند، آن‌هم با به اشتراک گذاری بسته‌های ضبط شده و سپس تحلیل جمعی آن‌ها زمانی که ناهنجاری‌های خاص پروتکلی مشاهده شود یا نیازهای ویژه‌ای مطرح گردد.

+ چرا از وایرشارک استفاده کنیم؟

وایرشارک مجموعه گسترده‌ای از ویژگی‌ها را ارائه می‌دهد. علاوه بر محبوبیت، برخی از نقاط قوت وایرشارک عبارتند از:

- ❖ رایگان: وایرشارک همچنان یکی از بهترین ابزارهای رایگان برای تحلیل شبکه باقی مانده است. این ابزار به طور مکرر توسط مدیران شبکه، ارائه‌دهندگان خدمات اینترنت (ISPs)، دولت‌ها و حتی مدیران شبکه‌های خانگی برای درک مشکلات شبکه و تأثیر تغییرات توصیه و استفاده می‌شود.
- ❖ پشتیبانی از چندین پلتفرم: وایرشارک با اکثر محیط‌های سیستم عامل از جمله ویندوز، لینوکس و مک‌اواس سازگاری کامل دارد.
- ❖ مستندسازی جامع: وایرشارک در طول زمان جامعه بزرگی از کاربران را جذب کرده که همگی در تولید مستندات مشارکت داشته‌اند. با این حجم از مشارکت‌ها، کاربران به راحتی می‌توانند به راهنمایی‌های جامع برای اطلاعات ضروری دسترسی پیدا کنند.
- ❖ منوهای کشویی و کدگذاری رنگی: وایرشارک شامل مجموعه‌ای از ابزارهای داخلی است که از بررسی عمیق صدها پروتکل پشتیبانی می‌کنند، به طوری که کاربران می‌توانند هزاران بسته را مشاهده و تحلیل کنند. علاوه بر این، فیلترهای نمایش قدرتمندی دارد که به کاربران کمک می‌کند به سرعت ترافیک شبکه خاصی را پیدا کنند.

❖ پشتیبانی از تعداد زیادی پروتکل: وایرشارک قابلیت‌های پیشرفته تشخیص برای صدها نوع بسته یا پروتکل مختلف را فراهم می‌کند که نه تنها پروتکل‌های متداول مانند TCP، UDP، HTTP یا DNS، بلکه طیف گسترده‌ای از اعضای خانواده پروتکل‌ها را پوشش می‌دهد.

وایرشارک در ابتدا به عنوان یک پروژه شخصی برای یک ابتکار منبع باز ایجاد شد، اما پایه کد آن در طول سال‌ها توسط افراد مختلف توسعه یافته است. از آنجا که وایرشارک به طور گسترده توسط سازمان‌های خصوصی و حرفه‌ای در مقیاس‌های مختلف استفاده می‌شود، این ابزار در سال‌های اخیر بهبود یافته، با قابلیت‌های رمزگشایی پیشرفته ارتقا پیدا کرده و با عملکردهای اسکن امنیتی تقویت شده تا نیازهای دقیق امنیتی و انطباق تحلیلگران شبکه را برآورده سازد. با پشتیبانی از طیف متنوعی از پلتفرم‌های سیستم عامل، مستندات دقیق، جامعه توسعه‌دهندگان فعال و پشتیبانی خیره‌کننده از تحلیل پروتکل‌ها، کاربران به سختی می‌توانند نقشی در استفاده از وایرشارک به عنوان ابزاری برای تحلیل شبکه پیدا کنند.

وایرشارک یک تحلیلگر پروتکل شبکه قدرتمند و منبع باز است که به کاربران امکان می‌دهد ترافیک شبکه را به صورت بلادرنگ یا از فایل‌های ضبط شده، بررسی و تحلیل کنند. این ابزار به گونه‌ای طراحی شده که به مدیران شبکه، متخصصان امنیتی و توسعه‌دهندگان در درک و عیب‌یابی ارتباطات شبکه کمک کند، آن را به ابزاری همه‌کاره برای نقش‌های فنی مختلف تبدیل کرده است.

ویژگی‌ها و قابلیت‌های کلیدی وایرشارک:

❖ ضبط بسته‌ها (Packet Capture): وایرشارک می‌تواند ترافیک زنده شبکه را از رابط‌های مختلفی از جمله اترنت، وای‌فای و بلوتوث ضبط کند. این قابلیت به کاربران امکان می‌دهد داده‌ها را هنگام عبور از شبکه مانیتور کنند و دیدی بلادرنگ از ارتباطات داشته باشند.

❖ رمزگشایی پروتکل‌ها (Protocol Decoding): این ابزار از طیف گسترده‌ای از پروتکل‌ها مانند TCP، UDP، HTTP و SMB پشتیبانی می‌کند و می‌تواند آنها را به اطلاعات قابل فهم برای کاربر تبدیل کند. این ویژگی برای تحلیل محتوا و ساختار بسته‌های شبکه حیاتی است.

❖ فیلترینگ (Filtering): کاربران می‌توانند هم از فیلترهای نمایش و هم از فیلترهای ضبط برای تمرکز بر انواع خاصی از ترافیک استفاده کنند. به عنوان مثال، می‌توان از فیلتر tcp port 80 برای مانیتورینگ ترافیک HTTP استفاده کرد که کارایی تحلیل را افزایش می‌دهد.

❖ آمار و تحلیل (Statistics and Analysis): وایرشارک ابزارهایی برای تحلیل الگوهای ترافیک، معیارهای عملکرد و توزیع پروتکل‌ها ارائه می‌دهد که برای شناسایی ناهنجاری‌ها یا گلوگاه‌های عملکردی ضروری هستند.

وایرشارک یک ابزار چندسکویی است که از ویندوز، مک‌اواس و لینوکس پشتیبانی می‌کند و دسترسی طیف گسترده‌ای از کاربران را فراهم می‌سازد. ماهیت منبع باز این نرم‌افزار (تا تاریخ 1 مارس 2025) امکان مشارکت جامعه کاربری و سفارشی‌سازی را فراهم کرده که به افزایش کارایی آن کمک می‌کند.

+ارتباط با Red Team

تیم‌های قرمز متخصصان امنیتی هستند که با انجام عملیات امنیتی تهاجمی، حملات سایبری را شبیه‌سازی می‌کنند تا آسیب‌پذیری‌ها را شناسایی و قابلیت‌های دفاعی سازمان را آزمایش کنند. وایرشارک به دلایل خاصی برای کار آنها بسیار مرتبط است که هر کدام به توانایی آنها در برنامه‌ریزی و اجرای حملات مؤثر کمک می‌کند:

- 1. درک پروتکل‌های شبکه**: با مطالعه ترافیک شبکه ضبط شده توسط وایرشارک، تیم‌های قرمز می‌توانند درک عمیقی از عملکرد پروتکل‌های مختلف به دست آورند. این دانش برای شناسایی آسیب‌پذیری‌های بالقوه و ساخت اکسپلویت‌ها حیاتی است. به عنوان مثال، درک رفتار پروتکل SMB می‌تواند به تکنیک‌های استخراج اعتبار کمک کند.
- 2. شناسایی بردارهای حمله**: تجزیه و تحلیل ترافیک شبکه به تیم‌های قرمز کمک می‌کند نقاط ورود احتمالی و ضعف‌های موجود در وضعیت امنیتی شبکه را شناسایی کنند. آنها می‌توانند سرویس‌های نادرست پیکربندی شده، ارتباطات رمز نشده یا پروتکل‌های قدیمی را که قابل بهره‌برداری هستند، تشخیص دهند.
- 3. تجزیه و تحلیل ترافیک مخرب**: وایرشارک می‌تواند برای درک رفتار بدافزار یا سایر فعالیت‌های مخرب استفاده شود که به توسعه راهبردهای فرار از تشخیص کمک می‌کند. به عنوان مثال، تیم‌های قرمز می‌توانند ترافیک فرمان و کنترل (C2) را تحلیل کنند تا مطمئن شوند ایمپلنت‌های آنها بدون تشخیص در حال ارتباط هستند.

4. **تأیید موفقیت حمله** :تیم‌های قرمز می‌توانند ترافیک تولید شده توسط حملات خود را ضبط و تحلیل کنند تا تأیید کنند که آیا به نتایج مورد نظر بدون تشخیص توسط دفاع‌های تیم آبی دست یافته‌اند یا خیر. این کار به ویژه برای تأیید حرکت جانبی یا تلاش‌های استخراج داده مفید است.

نکته جالب توجه این است که در حالی که تیم‌های قرمز معمولاً بر پنهانکاری تمرکز دارند، وایرشارک می‌تواند در محیط‌های کنترل شده، مانند مراحل پس از بهره‌برداری، برای جمع‌آوری اطلاعات از سیستم‌های به خطر افتاده نیز استفاده شود. این استفاده دوگانه هم برای یادگیری و هم برای تحلیل عملیاتی وایرشارک را به ابزاری همه‌کاره در جعبه ابزار آنها تبدیل کرده است.

راه‌اندازی وایرشارک برای امنیت تهاجمی

برای استفاده مؤثر از وایرشارک در عملیات تیم قرمز، راه‌اندازی و پیکربندی صحیح ابزار ضروری است تا مطمئن شویم نرم‌افزار با نیازهای خاص فعالیت‌های امنیتی تهاجمی سازگار شده است. مراحل زیر این فرآیند را با ملاحظات ویژه برای سفارشی‌سازی‌های مورد نیاز تیم قرمز تشریح می‌کند:

مرحله ۱: نصب

۱. **دانلود وایرشارک** : به وبسایت رسمی وایرشارک (www.wireshark.org) مراجعه کنید آخرین نسخه مناسب برای سیستم عامل خود را دانلود نمایید. تا تاریخ ۱ مارس ۲۰۲۵، مطمئن شوید نسخه سازگار با معماری سیستم شما (۳۲ بیتی یا ۶۴ بیتی) را انتخاب می‌کنید.

۲. **نصب وایرشارک**: دستورالعمل‌های نصب مربوط به سیستم عامل خود را دنبال کنید. در ویندوز: این فرآیند شامل اجرای نصب‌کننده با مجوزهای مدیریتی است. در لینوکس: ممکن است نیاز به استفاده از مدیران بسته مانند apt یا yum داشته باشید. اطمینان حاصل کنید که مجوزهای لازم برای نصب نرم‌افزار را دارید این موضوع برای تیم‌های قرمز که در محیط‌های کنترل شده کار می‌کنند حیاتی است.

مرحله ۲: پیکربندی

۱. **اینترفیس‌های ضبط:** هنگام اجرای وایرشارک، با اینترفیس‌های شبکه موجود در سیستم خود آشنا شوید. اینترفیس مناسب برای ضبط ترافیک را انتخاب کنید، مثلاً eth0 برای Ethernet یا یک اینترفیس Wi-Fi. هکرهای Red Team ممکن است نیاز داشته باشند ترافیک را از سیستم‌های مورد حمله قرار گرفته ضبط کنند، که ممکن است شامل تنظیم TAP‌های شبکه یا استفاده از ابزارها برای هدایت ترافیک به دستگاه تحلیلی آنها باشد.

۲. فیلترها :

یاد بگیرید که از فیلترهای نمایشی و ضبطی استفاده کنید تا ترافیکی که علاقه‌مندید را محدود کنید. برای مثال، برای ضبط ترافیک HTTP از عبارت tcp port 80 استفاده کنید؛ برای SMB از پورت 445. این کار به ویژه برای تمرکز روی ترافیک‌های مرتبط با حمله مفید است، مانند تبادل اطلاعات ورود (credential exchange) یا ارتباطات C2.

۳. تنظیمات (Preferences) :

تنظیمات وایرشارک را مطابق با نیاز خود سفارشی کنید. این موضوع شامل تنظیم گزینه‌های پیش‌فرض ضبط، فعال یا غیرفعال کردن پروتکل‌های خاص برای تحلیل و تغییر گزینه‌های نمایش جهت خوانایی بهتر می‌شود. برای مثال، فعال کردن گزینه "Reassemble fragmented IPv4 datagrams" در مسیر Edit > Preferences > Protocols > IPv4 می‌تواند به تحلیل ترافیک‌های شکسته شده کمک کند.

مرحله ۳: سفارشی‌سازی‌ها برای Red Teamers

۱. Dissectors

در صورت کار با پروتکل‌های سفارشی یا مخصوص (Proprietary)، ممکن است نیاز داشته باشید Dissectors خاص خود را بسازید یا از Dissectors های موجود استفاده کنید تا بتوانید ترافیک را به درستی رمزگشایی کنید. این موضوع به‌ویژه زمانی اهمیت پیدا می‌کند که ترافیک برنامه‌های اختصاصی مورد استفاده در محیط تارگت را تحلیل می‌کنید و به شناسایی آسیب‌پذیری‌ها کمک می‌کند.

۲. اسکریپت نویسی :

از قابلیت‌های اسکریپت‌نویسی داخلی وایرشارک مثل Lua یا ابزارهای خارجی مانند tshark (نسخه خط فرمانی وایرشارک) برای اتوماتیک کردن وظایف استفاده کنید. برای مثال، اسکریپت‌ها را می‌توان برای استخراج اطلاعات خاص از ضبط‌ها به کار برد، مانند استخراج هش‌های NTLM از ترافیک SMB، همانطور که در فصل‌های بعدی توضیح داده خواهد شد.

۳. نکات امنیتی :

همیشه مطمئن شوید که ضبط ترافیک شبکه در چارچوب محدوده تعیین شده و مطابق با سیاست‌های قانونی و سازمانی انجام می‌شود. Red Teamer ها باید در شرایطی مجاز عمل کنند که معمولاً در مدارک (Rules of Engagement) مشخص شده است، تا از عواقب قانونی جلوگیری شود. این موضوع بسیار مهم است، چرا که ضبط غیرمجاز ترافیک شبکه می‌تواند منجر به پیامدهای جدی شود.

Table: Comparison of Wireshark Features for Red and Blue Teams

Feature	Relevance to Red Teamers	Relevance to Blue Teamers
Packet Capture	Used to analyze attack traffic and verify success	Used to detect intrusions and anomalies
Protocol Decoding	Helps identify vulnerabilities for exploitation	Aids in understanding normal traffic patterns
Filtering	Focuses on specific attack-related traffic	Filters out noise to identify threats
Statistics and Analysis	Verifies attack effectiveness and network layout	Monitors network performance and security

جدول: مقایسه ویژگی های Wireshark برای تیم های قرمز و آبی

ارتباط با تیم های آبی	مربوط به تیم قرمز	ویژگی
برای تشخیص نفوذ و ناهنجاری استفاده می شود	برای تجزیه و تحلیل ترافیک حمله و تأیید موفقیت استفاده می شود	ضبط بسته
به درک الگوهای عادی ترافیک کمک می کند	به شناسایی آسیب پذیری ها برای بهره برداری کمک می کند	رمزگشایی پروتکل
برای شناسایی تهدیدات، نویز را فیلتر می کند	بر ترافیک خاص مرتبط با حمله تمرکز می کند	فیلتر کردن
عملکرد و امنیّت شبکه را رصد می کند	اتریبختی حمله و طرح شبکه را تأیید می کند	آمار و تجزیه و تحلیل

جدول زیر دوگانگی کاربرد وایرشارک را برجسته می سازد و نقش آن را هم در عملیات امنیتی تهاجمی و هم دفاعی نشان می دهد. این نکته ای مهم برای تیم های قرمز است تا دیدگاه تیم های آبی (دفاعی) را درک کنند.

+ فصل ۲ – پایه های وایرشارک: درک ترافیک شبکه

وایرشارک (Wireshark) یک ابزار رایگان و منبع باز است که به شما اجازه می دهد ترافیک شبکه، مانند ایمیل ها یا مرور وب، را مشاهده و تحلیل کنید. این امر با کپچر کردن داده ها در حال حرکت در شبکه انجام می شود. وایرشارک قادر است پروتکل های مختلفی را رمزگشایی کند و فرآیند درک آنچه در شبکه اتفاق می افتد را ساده تر کند. این ابزار بر روی سیستم عامل های ویندوز، مک اواس و لینوکس قابل اجرا است (تا تاریخ ۱ مارس ۲۰۲۵).

Packet Capturing Fundamentals

کپچر کردن بسته ها (Packet Capturing)، فرآیند کپچر کردن و ذخیره کردن بسته های شبکه در حال حرکت در طول شبکه است. برای شروع، برنامه Wireshark را اجرا کنید، رابط شبکه مورد نظر را (مانند وای فای) انتخاب کنید و روی گزینه "Start" کلیک کنید تا کپچر ترافیک آغاز شود. شما می توانید از فیلترهای کپچر (Capture Filters) مانند tcp 80 port برای متمرکز شدن روی نوع خاصی از ترافیک (مانند HTTP) استفاده کنید. همچنین می توانید ضبط ها را در قالب هایی مانند pcapng ذخیره کنید و در آینده تحلیل کنید.

Filters and Display Options

پس از ضبط داده‌ها، می‌توانید از فیلترهای نمایش (Display Filters) استفاده کنید تا تنها بسته‌های خاصی را مشاهده کنید، مثلاً http برای ترافیک HTTP. این فیلترها را در قسمت مخصوص فیلتر وارد می‌کنید. همچنین می‌توانید بسته‌ها را بر اساس قوانین مشخص رنگی کنید؛ مثلاً تمام ترافیک HTTP را سبز کنید تا الگوها را راحت‌تر تشخیص دهید. علاوه بر این، می‌توانید بسته‌ها را بر اساس ستون‌هایی مانند زمان (timestamp)، IP مبدأ یا مقصد مرتب یا گروه‌بندی کنید.

رمزگشایی پروتکل‌ها (Decoding Protocols)

وایرشارک قادر به رمزگشایی پروتکل‌هایی مانند TCP (برای ارتباطات قابل اعتماد)، UDP (برای ارتباط بدون اتصال و سریع‌تر) و HTTP (برای ترافیک وب) است. با انتخاب یک بسته و گسترش لایه مربوط به پروتکل در پنجره جزئیات، می‌توانید داده‌های قابل خواندن مانند درخواست‌ها یا پاسخ‌های HTTP را مشاهده کنید. همچنین وایرشارک از پروتکل‌های دیگری مانند DNS، SMTP و SSL/TLS نیز پشتیبانی می‌کند و امکان به‌روزرسانی Dissectors آن را برای پروتکل‌های سفارشی فراهم می‌کند.

این فصل با عنوان "مبانی وایرشارک: درک ترافیک شبکه"، فصل دوم از کتاب "کاوش در وایرشارک برای Red Teamers: از مبانی تا تکنیک‌های پیشرفته تحلیل شبکه" است. هدف این فصل این است که به متخصصان Red Team (تیم قرمز)، یعنی افراد حرفه‌ای امنیتی که با شبیه‌سازی حملات، دفاع‌های سازمانی را آزمایش می‌کنند، دانش بنیادی از نحوه استفاده از وایرشارک برای کپچر کردن بسته‌ها، فیلتر کردن، گزینه‌های نمایش و رمزگشایی پروتکل‌ها را بدهد. اطلاعات این فصل مطابق با آخرین منابع و روش‌های موجود در تاریخ ۱ مارس ۲۰۲۵ به‌روز است.

مبانی کپچر کردن بسته‌های شبکه (Packet Capturing)

ضبط بسته‌ها (Packet Capturing) فرآیند قطع و ذخیره‌سازی بسته‌های شبکه‌ای است که در حال عبور از یک شبکه هستند و پایه‌گذار تحلیل ترافیک شبکه با استفاده از ابزارهایی مانند Wireshark می‌باشد. این بخش مراحل و نکات مربوط به ضبط مؤثر بسته‌ها را شرح می‌دهد که به‌ویژه برای اعضای تیم قرمز در عملیات امنیتی تهاجمی اهمیت دارد.

شروع کپچر کردن

برای شروع ضبط ترافیک شبکه با Wireshark :

1. **اجرای Wireshark:** برنامه Wireshark را باز کنید و اطمینان حاصل کنید که آخرین نسخه آن (تا تاریخ 1 مارس 2025) را از وبسایت رسمی Wireshark دانلود کرده‌اید.
2. **انتخاب رابط شبکه:** رابط شبکه‌ای که می‌خواهید ترافیک آن را ضبط کنید، انتخاب کنید. این می‌تواند یک کارت اترنت (eth0) ، اینترفیس Wi-Fi یا هر دستگاه شبکه دیگری باشد. اعضای تیم قرمز ممکن است نیاز داشته باشند ترافیک را از سیستم‌های آسیب‌دیده کپچر کنند که این می‌تواند شامل راه‌اندازی تپ‌های شبکه یا استفاده از ابزارهایی برای هدایت ترافیک به دستگاه تحلیل آن‌ها باشد.
3. **شروع ضبط:** روی دکمه "Start" کلیک کنید تا کپچر بسته‌ها آغاز شود. به‌طور پیش‌فرض، Wireshark تمام ترافیک عبوری از اینترفیس انتخابی را کپچر می‌کند که می‌تواند حجم زیادی از داده‌ها را ایجاد کند، به‌ویژه در شبکه‌های شلوغ.

یک نکته غیرمنتظره در اینجا این است که کپچر ترافیک در اینترفیس‌های پر ترافیک، مانند آن‌هایی که در دیتاسنترها هستند، ممکن است باعث مشکلات عملکردی شود، بنابراین اعضای تیم قرمز باید به قابلیت‌های سخت‌افزاری توجه کنند و ممکن است برای کپچر حجم بالا از ابزارهایی مانند dumpcap استفاده کنند.

فیلترهای ضبط CAPTURE FILTERS

فیلترهای کپچر به شما این امکان را می‌دهند که بسته‌هایی را بر اساس معیارهای خاصی، مانند آدرس‌های IP مبدا یا مقصد، پورت‌ها یا پروتکل‌ها، کپچر کنید. این فیلترها در سطح هسته سیستم اعمال می‌شوند که باعث می‌شود کارآمد باشند و مقدار داده‌های کپچر شده را کاهش دهند. این ویژگی به‌ویژه برای اعضای تیم قرمز که روی ترافیک مرتبط با حملات خاص تمرکز دارند، مفید است.

برای تنظیم یک فیلتر کپچر در Wireshark :

1. رفتن به گزینه‌های کپچر: از منوی "Capture" ، گزینه "Options" را انتخاب کنید.

2. تنظیم فیلتر: در قسمت "Capture filter" ، عبارت فیلتر خود را وارد کنید. برای مثال، برای کپچر فقط ترافیک HTTP، از عبارت tcp port 80 استفاده کنید؛ برای SMB، از port 445 استفاده کنید. این مثال‌ها در راهنمای کاربری Wireshark مستند شده‌اند.

3. شروع ضبط: روی دکمه "Start" کلیک کنید تا کپچر با فیلتر اعمال شده آغاز شود.

عبارت‌های فیلتر کپچر رایج شامل موارد زیر هستند:

❖ host 192.168.1.100 برای کپچر ترافیک به یا از یک آدرس IP خاص.

❖ port 443 برای کپچر ترافیک در یک پورت خاص (برای مثال HTTPS)

❖ tcp برای کپچر فقط ترافیک TCP .

این فیلترسازی نویز را کاهش می‌دهد و به اعضای تیم قرمز این امکان را می‌دهد که روی ترافیک مرتبط، مانند ارتباطات فرمان و کنترل یا تبادل اعتبارنامه‌ها، تمرکز کنند.

ذخیره کردن کپچرها SAVING CAPTURES

داده‌های ضبط شده می‌توانند برای تحلیل‌های بعدی ذخیره شوند که برای اعضای تیم قرمز که ترافیک را پس از اتمام عملیات بررسی می‌کنند، بسیار مهم است. برای ذخیره‌سازی یک کپچر:

1. متوقف کردن کپچر: روی دکمه "Stop" کلیک کنید تا کپچر متوقف شود.

2. ذخیره فایل: از منوی "File" ، گزینه "Save As" را انتخاب کنید و یک مکان و نام فایل برای فایل کپچر شده تعیین کنید.

Wireshark از فرمت‌های مختلف فایل پشتیبانی می‌کند، اما فرمت پیش‌فرض آن pcapng است که به‌خاطر انعطاف‌پذیری و سازگاری با ابزارهای دیگر توصیه می‌شود. این فرمت ویژگی‌هایی مانند حل نام‌ها و پشتیبانی از چندین اینترفیس را فراهم می‌کند که قابلیت‌های تحلیل را افزایش می‌دهد.

فیلترها و گزینه‌های نمایش

پس از ضبط ترافیک، Wireshark روش‌های متعددی برای فیلتر کردن و نمایش داده‌ها ارائه می‌دهد تا تحلیل را کارآمدتر کند، که برای اعضای تیم قرمز جهت شناسایی سریع الگوها یا ناهنجاری‌ها بسیار حیاتی است.

فیلترهای نمایش (Display Filters)

فیلترهای نمایش برای تعیین این استفاده می‌شوند که کدام بسته‌ها پس از کپیچر در پنل لیست بسته‌ها نمایش داده شوند. برخلاف فیلترهای کپیچر، این فیلترها بر روی اینکه چه بسته‌هایی کپیچر شوند تأثیر نمی‌گذارند؛ بلکه فقط نحوه نمایش آن‌ها را کنترل می‌کنند و در نتیجه، انعطاف‌پذیری بیشتری برای تحلیل پس از کپیچر فراهم می‌کنند.

برای اعمال یک فیلتر نمایش:

ورودی فیلتر: در قسمت "Filter" در بالای پنجره اصلی، عبارت فیلتر خود را تایپ کنید. به عنوان مثال، http برای نمایش تمام بسته‌های HTTP، یا ip.addr == 192.168.1.100 برای نمایش بسته‌هایی که آدرس IP آن‌ها برابر با 192.168.1.100 است، همان‌طور که در ویکی Wireshark توضیح داده شده است.

1. اعمال فیلتر: کلید Enter را فشار دهید یا روی دکمه "Apply" کلیک کنید.

فیلترهای نمایش بسیار انعطاف‌پذیرتر هستند و می‌توانند بر اساس دامنه وسیع‌تری از ویژگی‌های بسته‌ها تعریف شوند، مانند فلگ‌های TCP (مثلاً tcp.flags == 0x02 برای بسته‌های SYN) یا فیلدهای خاص مربوط به یک پروتکل خاص.

قوانین رنگ‌بندی (Coloring Rules)

Wireshark این امکان را به شما می‌دهد که بسته‌ها را بر اساس معیارهای مشخصی رنگ‌بندی کنید، که باعث می‌شود شناسایی انواع خاصی از ترافیک با یک نگاه آسان‌تر شود. این قابلیت به‌ویژه برای اعضای تیم قرمز که به دنبال الگوهای مشکوک یا مخرب هستند، بسیار مفید است.

برای تنظیم قوانین رنگ بندی:

1. رفتن به تنظیمات: از منوی "Edit" ، گزینه "Preferences" را انتخاب کنید.
2. قوانین رنگ بندی: در بخش "User Interface" ، وارد قسمت "Coloring Rules" شوید.
3. افزودن قانون: روی "New" کلیک کنید تا یک قانون جدید اضافه کنید، فیلتر مورد نظر و رنگ دلخواه را مشخص کرده و روی "OK" کلیک کنید.

برای مثال، می‌توانید تمام بسته‌های HTTP را سبز کنید یا بسته‌های TCP SYN را قرمز نمایش دهید تا تحلیل بصری ساده‌تر شود. این ویژگی قابل تنظیم است و می‌تواند برای برجسته‌سازی ترافیک مرتبط با حملات استفاده شود؛ مثلاً می‌توان تمام درخواست‌های آغاز جلسه SMB را رنگی خاص داد تا در تحلیل استخراج اعتبارنامه‌ها سریع‌تر شناسایی شوند.

مرتب‌سازی و گروه‌بندی

بسته‌ها را می‌توان بر اساس ستون‌های مختلفی در پنل لیست بسته‌ها مرتب کرد، مانند زمان‌سنج، آدرس IP مبدا یا پروتکل. همچنین می‌توان گروه‌بندی انجام داد تا بسته‌ها بر اساس ویژگی‌های خاصی سازماندهی شوند که در شناسایی الگوها کمک می‌کند.

برای مرتب‌سازی یا گروه‌بندی بسته‌ها:

1. روی هدر ستون کلیک راست کنید: گزینه‌های "Sort Ascending" (مرتب‌سازی صعودی)، "Sort Descending" (مرتب‌سازی نزولی) یا "Group By" (گروه‌بندی بر اساس) را برای ستون مورد نظر انتخاب کنید.

این ویژگی برای شناسایی سریع الگوها مفید است، مانند گروه‌بندی بر اساس آدرس IP مبدا برای مشاهده تمام ترافیک مربوط به یک میزبان خاص که ممکن است آسیب‌دیده باشد، که برای اعضای تیم قرمز در تحلیل حرکتهای جانبی (lateral movement) ارزشمند است.

رمزگشایی پروتکل‌ها (TCP, UDP, HTTP و غیره)

Wireshark از تعداد زیادی پروتکل شبکه پشتیبانی می‌کند و آن‌ها را رمزگشایی می‌کند، به‌طوری‌که محتوای بسته‌ها را به شکلی قابل فهم برای انسان نمایش می‌دهد. این قابلیت برای اعضای تیم قرمز بسیار حیاتی است، زیرا به آن‌ها کمک می‌کند ارتباطات شبکه را درک کرده و از آن‌ها بهره‌برداری کنند.

UDP و TCP

TCP • (پروتکل کنترل انتقال): برای ارتباطات قابل اعتماد و مبتنی بر اتصال استفاده می‌شود. Wireshark. فلگ‌های TCP، شماره‌های توالی، شماره‌های تأییدیه و سایر اطلاعات کنترلی را نمایش می‌دهد. برای اعضای تیم قرمز، تحلیل فلگ‌های TCP می‌تواند به شناسایی آغاز (SYN) یا خاتمه (RST، FIN) اتصال کمک کند که برای نقشه‌برداری از توپولوژی شبکه یا شناسایی قوانین فایروال مفید است.

UDP • (پروتکل دیتاگرام کاربر): برای ارتباطات بدون اتصال استفاده می‌شود و برای برنامه‌هایی مانند DNS یا پخش ویدئو مناسب است. این پروتکل پورتهای مبدا و مقصد و همچنین بار داده (payload) را نشان می‌دهد که می‌توان آن را برای تحلیل استخراج داده‌های غیرمحرمانه (unencrypted) بررسی کرد.

HTTP

HTTP (پروتکل انتقال ابرمتن) برای ترافیک وب استفاده می‌شود و یک تارگت رایج برای اعضای تیم قرمز است. Wireshark می‌تواند درخواست‌ها و پاسخ‌های HTTP را رمزگشایی کرده و روش‌ها (GET، POST) آدرس‌های URL، هدرها و پیلود داده‌ها را نمایش دهد.

برای مشاهده جزئیات HTTP :

1. **انتخاب بسته** : یک بسته با ترافیک HTTP را از لیست بسته‌ها انتخاب کنید.
2. **گسترش لایه HTTP** : در پنل جزئیات بسته، بخش "HTTP" را باز کنید تا اطلاعات درخواست یا پاسخ را مشاهده کنید، مانند اعتبارنامه‌های در متن ساده در درخواست‌های POST که ممکن است یک آسیب‌پذیری برای بهره‌برداری باشد.

دیگر پروتکل‌های رایج

• **DNS** (سیستم نام دامنه): برای تبدیل نام دامنه به آدرس IP استفاده می‌شود. Wireshark. نوع درخواست‌ها (مانند A، MX)، پاسخ‌ها و رکوردهای منابع را نمایش می‌دهد که تیم قرمز می‌تواند از آن‌ها برای شناسایی دامنه‌ها یا کشف دامنه‌های فرمان و کنترل (C2) استفاده کند.

• **SMTP** (پروتکل ساده انتقال ایمیل): برای ارسال ایمیل‌ها استفاده می‌شود. این پروتکل فرمان‌هایی مانند HELO، MAIL FROM و RCPT TO و همچنین پاسخ‌های مرتبط با ارسال ایمیل را نشان می‌دهد که برای تحلیل ترافیک کمپین‌های فیشینگ مفید است.

• **SSL/TLS** (لایه سوکت‌های امن / امنیت انتقال): برای ارتباطات رمزگذاری‌شده به کار می‌رود. با پیکربندی مناسب، مانند ارائه کلیدهای جلسه، Wireshark می‌تواند نشست‌های SSL/TLS را رمزگشایی کرده و محتوای آن‌ها را نمایش دهد؛ از جمله اطلاعات حساسی مانند کلیدهای API یا توکن‌های نشست، که در فصل‌های بعدی به‌طور کامل‌تر بررسی می‌شوند.

PROTOCOL DISSECTORS

Wireshark از Dissectorها برای رمزگشایی پروتکل‌های خاص استفاده می‌کند. این‌ها قطعه کدهایی هستند که داده‌های بسته‌ها را بر اساس مشخصات هر پروتکل تجزیه و تحلیل می‌کنند تا تحلیل دقیق‌تری انجام شود.

اگر یک پروتکل توسط Wireshark شناسایی نشود یا به درستی رمزگشایی نشود، می‌توانید اقدامات زیر را انجام دهید:

1. بررسی تنظیمات: مطمئن شوید که پروتکل مورد نظر در تنظیمات Wireshark فعال است. برای این کار به مسیر `Edit > Preferences > Protocols` بروید.
2. به‌روزرسانی Wireshark: اطمینان حاصل کنید که از آخرین نسخه Wireshark استفاده می‌کنید، چون با گذر زمان dissector های جدید به آن افزوده می‌شوند. آخرین نسخه از وبسایت رسمی Wireshark قابل دریافت است.
3. Dissector سفارشی: برای پروتکل‌های خاص یا اختصاصی، ممکن است نیاز به نوشتن یا تهیه dissector سفارشی داشته باشید. این موضوع به‌ویژه برای تیم قرمز که برنامه‌های خاص و سفارشی‌شده در محیط هدف را تحلیل می‌کنند، اهمیت دارد.

Table: Comparison of TCP and UDP for Red Team Analysis

Feature	TCP Analysis	UDP Analysis
Connection Type	Connection-oriented, reliable	Connectionless, faster
Use Case for Red Team	Analyze session establishment, flags	Monitor unencrypted data, DNS queries
Example Filter	<code>tcp.flags == 0x02</code> (SYN packets)	<code>udp.port == 53</code> (DNS traffic)
Vulnerability	Session hijacking, RST injection	Data leakage, amplification attacks

جدول: مقایسه TCP و UDP برای تجزیه و تحلیل تیم قرمز

ویژگی	تجزیه و تحلیل TCP	تجزیه و تحلیل UDP
نوع اتصال	اتصال گرا، قابل اعتماد	بدون اتصال، سریعتر
استفاده از کیس برای تیم قرمز	تشکیل جلسه، پرچم ها را تجزیه و تحلیل کنید	نظارت بر داده های رمزگذاری نشده، پرس و جوی DNS
فیلتر مثال	<code>tcp.flags == 0x02</code> (بسته های SYN)	<code>udp.port == 53</code> (ترافیک DNS)
آسیب پذیری	ریودن جلسه، تزریق RST	نشت داده ها، حملات تقویتی

این جدول تفاوت‌ها را نشان می‌دهد و به اعضای تیم قرمز کمک می‌کند تا بر اساس اهداف خود، پروتکل مناسب برای تحلیل را انتخاب کنند.

فصل ۳ – تکنیک‌های متوسط: تحلیل ترافیک برای شناسایی (Reconnaissance)

شناسایی (Reconnaissance) یکی از مراحل حیاتی در عملیات تیم قرمز است که در آن تیم سعی می‌کند اطلاعاتی درباره شبکه تارگت جمع‌آوری کند تا آسیب‌پذیری‌های احتمالی را شناسایی کرده و برنامه‌ریزی دقیقی برای حملات خود داشته باشد. تحلیل ترافیک با استفاده از Wireshark نقش مهمی در این مرحله ایفا می‌کند، زیرا به اعضای تیم قرمز این امکان را می‌دهد که ترافیک شبکه را رهگیری و بررسی کرده و اطلاعات ارزشمندی استخراج کنند.

در این فصل به تکنیک‌هایی مانند شناسایی دستگاه‌ها و سرویس‌های موجود در شبکه، استخراج اعتبارنامه‌ها از پروتکل‌های متنی (cleartext)، و نقشه‌برداری از توپولوژی شبکه از طریق تحلیل بسته‌ها پرداخته می‌شود. هر کدام از این روش‌ها همراه با نمونه‌های عملی (POC) ارائه می‌شوند تا کاربرد آن‌ها در سناریوهای واقعی بهتر درک شود.

شناسایی دستگاه‌ها و سرویس‌های شبکه

برای اینکه بتوانید حملات رو به خوبی برنامه‌ریزی و اجرا کنید، باید انواع دستگاه‌ها و سرویس‌های موجود در شبکه تارگت رو بشناسید. این اطلاعات می‌تونه به شما کمک کنه تا نقاط ورودی احتمالی، سرویس‌های آسیب‌پذیر و ساختار

کلی شبکه رو پیدا کنید. نرم افزار وایرشارک (Wireshark) روش های مختلفی رو برای به دست آوردن این اطلاعات از طریق تحلیل ترافیک شبکه در اختیار شما قرار می دهد .

شناسایی انواع دستگاه ها با استفاده از آدرس MAC

هر اینترفیس شبکه یک آدرس MAC منحصر به فرد دارد که شامل شناسه سازمانی منحصر به فرد (OUI) است که می تواند سازنده دستگاه را نشان دهد. با تجزیه و تحلیل آدرس های MAC از ترافیک شبکه، تیم های قرمز می توانند نوع دستگاه های موجود مانند روترها، سوئیچ ها یا دستگاه های پایانی (endpoints) را شناسایی کنند.

اثبات مفهوم: شناسایی سازندگان دستگاه ها از طریق آدرس های MAC

1. گرفتن ترافیک ARP: بسته های ARP شامل آدرس های MAC هستند. از فیلتر گرفتن ترافیک ARP استفاده کنید تا ترافیکی که آدرس های IP را به آدرس های MAC تبدیل می کند، ذخیره کنید.

2. استخراج آدرس های MAC: در Wireshark، یک بسته ARP را انتخاب کنید و به فیلدهای "Source MAC Address" و "Destination MAC Address" در پنل جزئیات بسته نگاه کنید. این فیلدها معمولاً در لایه "Ethernet II" قرار دارند.

3. شناسایی سازندگان Wireshark: یک ویژگی داخلی دارد که می تواند OUI ها را به نام های سازندگان تبدیل کند. برای فعال کردن این ویژگی، به مسیر `MAC > Name Resolution > Preferences > Edit > Address` بروید و اطمینان حاصل کنید که گزینه "Resolve MAC addresses using a local table" فعال است. این ویژگی از پایگاه داده داخلی سازندگان Wireshark استفاده می کند که از منابعی مانند سازمان IEEE Registration Authority جمع آوری شده است.

همچنین، برای جستجوی دستی، می‌توانید از ابزارهای آنلاین مانند OUI Lookup در Wireshark یا IEEE OUI و Company Ids برای شناسایی سازنده بر اساس OUI آدرس MAC (سه بایت اول، مانند A:2F 00:1 برای Intel) استفاده کنید.

یک نکته غیرمنتظره این است که در حالی که OUIها نشان‌دهنده سازنده هستند، همیشه تولیدکننده چیپست را نشان نمی‌دهند، زیرا برخی از فروشندگان چیپست‌های شخص ثالث را تحت OUI خود ثبت می‌کنند، که این موضوع باعث پیچیدگی در شناسایی دستگاه‌ها می‌شود.

شناسایی سرویس‌ها از طریق شماره پورت‌ها

سرویس‌ها معمولاً بر روی شماره‌های پورت استاندارد اجرا می‌شوند که می‌توان از آن‌ها برای شناسایی سرویس‌ها استفاده کرد. به عنوان مثال، پورت 80 معمولاً با HTTP، پورت 443 با HTTPS و پورت 22 با SSH مرتبط است. با مشاهده پورت‌های در حال استفاده، تیم‌های قرمز می‌توانند سرویس‌ها اجرا شده در شبکه را استنباط کنند.

اثبات مفهوم : فهرست کردن سرویس‌ها بر اساس پورت‌های مشاهده شده

1. گرفتن ترافیک شبکه: ترافیک را بدون اعمال فیلتر آغاز کنید تا تمام پورت‌های فعال مشاهده شوند و دید کاملی از فعالیت شبکه داشته باشید. برای شروع از دکمه "Start Capturing" در Wireshark استفاده کنید.

2. تحلیل شماره‌های پورت TCP و UDP: در Wireshark، به ستون "Destination Port" برای بسته‌های TCP و UDP در پنجره فهرست بسته‌ها نگاه کنید. از ستون "Protocol" استفاده کنید تا ببینید کدام پروتکل در حال استفاده است، زیرا Wireshark به طور خودکار این اطلاعات را رمزگشایی می‌کند.

3. مطابقت پورت‌ها با سرویس‌ها: از شماره‌های پورت شناخته شده برای شناسایی سرویس‌ها استفاده کنید، همانطور که در منابعی مانند "IANA Service Name and Transport Protocol Port Number Registry" آمده است.

- پورت 80: HTTP
- پورت 443: HTTPS
- پورت 22: SSH
- پورت 21: FTP
- پورت 23: Telnet

برای پورت‌های غیر استاندارد، به دنبال الگوها یا رفتارهای شناخته شده سرویس‌ها باشید، مانند پورت‌های غیرمعمول برای HTTP (مثلاً 8080)، و با بررسی محتوای بسته‌ها صحت آن را تأیید کنید.

نکته برای تیم‌های قرمز: برخی از سرویس‌ها ممکن است به دلیل سیاست‌های امنیتی از پورت‌های غیر استاندارد استفاده کنند، بنابراین تنها بر اساس شماره پورت‌ها نمی‌توان به طور قطعی به نتیجه رسید. برای تأیید، این اطلاعات را با امضای پروتکل‌ها تطبیق دهید.

تشخیص امضاها (RECOGNIZING PROTOCOL SIGNATURES)

برخی پروتکل‌ها دارای امضاها یا الگوهای منحصر به فردی در ترافیک خود هستند که می‌توان آن‌ها را شناسایی کرد، مانند رشته‌ها یا هدرهای خاص. به عنوان مثال، ترافیک HTTP اغلب با "GET" یا "POST" آغاز می‌شود، در حالی که ترافیک DNS دارای قالب‌های مشخصی برای درخواست‌ها و پاسخ‌ها همراه با نوع رکورد خاص است.

اثبات مفهوم: شناسایی پروتکل‌ها یا برنامه‌های خاص

1. گرفتن ترافیک: ترافیک مربوط به یک برنامه یا پروتکل مشخص را با استفاده از فیلترهایی مانند tcp port 80 برای HTTP یا udp port 53 برای DNS ثبت کنید تا تمرکز روی ترافیک خاص باشد.

2. تحلیل محتوای بسته‌ها: به دنبال رشته‌ها یا الگوهای خاص در داده‌های بسته‌ها باشید. به عنوان مثال، ترافیک HTTP با عباراتی مانند "GET" یا "POST" شروع می‌شود که در لایه "HTTP" در پنجره جزئیات بسته قابل مشاهده است. ترافیک DNS نیز شامل درخواست‌هایی مانند رکورد "A" یا پاسخ‌هایی با آدرس‌های IP در لایه "DNS" می‌باشد.

3. استفاده از رمزگشای پروتکل Wireshark: Wireshark بسیاری از پروتکل‌ها را به صورت خودکار رمزگشایی می‌کند و شناسایی آن‌ها را ساده‌تر می‌سازد. اگر یک بسته به عنوان پروتکل خاصی (مثلاً "HTTP" یا "DNS") رمزگشایی شده باشد، به احتمال زیاد همان پروتکل است. لایه‌های پروتکل را در پنجره جزئیات بسته باز کنید تا داده‌ها را به صورت خوانا مشاهده کنید.

این روش به‌ویژه برای شناسایی پروتکل‌های سفارشی یا اختصاصی که ممکن است از پورت‌های استاندارد استفاده نکنند مفید است و شناسایی عمیق (Reconnaissance) را افزایش می‌دهد.

استخراج اطلاعات ورود (مانند نام کاربری و رمز عبور) از پروتکل‌های بدون رمزنگاری

بسیاری از پروتکل‌ها داده‌ها را به صورت متن ساده (Cleartext) منتقل می‌کنند، که این امکان را فراهم می‌سازد تا اطلاعات حساس مانند نام کاربری و رمز عبور را ضبط و مشاهده کرد. این موضوع برای تیم‌های قرمز در مرحله شناسایی (Reconnaissance) بسیار ارزشمند است.

این بخش به ضبط ترافیک پروتکل‌هایی مانند HTTP، FTP و Telnet می‌پردازد، جایی که اطلاعات ورود (Credentials) اغلب به صورت قابل مشاهده ارسال می‌شوند.

کپچر ترافیک HTTP (CAPTURING HTTP TRAFFIC)

ترافیک HTTP اغلب رمزنگاری نشده است، به‌ویژه در شبکه‌های داخلی یا برخی برنامه‌ها، که آن را در برابر استخراج اطلاعات ورود آسیب‌پذیر می‌سازد. اگرچه وبسایت‌های مدرن بیشتر از HTTPS استفاده می‌کنند، اما ممکن است به دلیل پیچیدگی نادرست یا سیستم‌های قدیمی هنوز از HTTP استفاده شود.

اثبات مفهوم: استخراج اطلاعات ورود از درخواست‌های HTTP

1. ضبط ترافیک HTTP

از فیلتر کپچر tcp port 80 استفاده کنید تا فقط ترافیک HTTP ثبت شود، چون احتمال دارد اطلاعات ورود به صورت متن ساده در این بسته ها ارسال شده باشند.

2. شناسایی درخواست های ورود (Login)

در لیست بسته ها به دنبال درخواست های POST مربوط به صفحات ورود بگردید؛ این ها معمولاً URL هایی مانند /authenticate یا /login.php دارند.

برای محدود کردن نمایش به درخواست های POST، از فیلتر نمایشی زیر استفاده کنید:

```
http.request.method == "POST"
```

3. استخراج داده های فرم

در جزئیات بسته، بخش "HTTP" را باز کنید و به دنبال فیلدهایی با عنوان "Form Item" بگردید. این فیلدها معمولاً شامل نام کاربری و رمز عبور هستند.

برای مثال ممکن است چنین چیزی ببینید:

Username : admin

Password: P@ssw0rd123

گاهی اوقات، Credentials ممکن است به عنوان پارامترهای پرس و جو در URL درخواست های GET ارسال شوند، اگرچه این کار برای داده های حساس کمتر رایج است.

4. ذخیره یا یادداشت کردن Credentials

Credentials استخراج شده را برای استفاده های بعدی، مانند تلاش برای ورود به سیستم تارگت یا ارتقاء دسترسی، ثبت کنید.

یک جزئی غیرمنتظره این است که اگرچه HTTPS ترافیک را رمزگذاری می کند، برخی از برنامه های داخلی یا سیستم های پیکربندی نشده ممکن است همچنان از HTTP استفاده کنند که فرصتهایی برای کپچر کردن Credentials در محیط های به ظاهر امن فراهم می آورد.

کپچر کردن ترافیک FTP

FTP در طول فرآیند ورود، Credentials را به صورت متنی و بدون رمزگذاری ارسال می‌کند، که آن را به تارگتی برای استخراج Credentials تبدیل می‌کند. با این حال، سیستم‌های مدرن اغلب از جایگزین‌های رمزگذاری شده مانند SFTP یا FTPS استفاده می‌کنند.

اثبات مفهوم: استخراج Credentials از ورود FTP

۱. کپچر کردن ترافیک FTP

از فیلتر کپچر استفاده کنید 21 tcp port : برای کپچر کردن ترافیک کانال کنترل FTP ، جایی که دستورات ورود ارسال می‌شوند.

۲. شناسایی دستورات USER و PASS

در FTP، نام کاربری با دستور "USER" و رمز عبور با دستور "PASS" ارسال می‌شود. به دنبال بسته‌هایی بگردید که این دستورات را در لیست بسته‌ها شامل می‌شوند، که تحت لایه "FTP" قابل مشاهده است.

۳. استخراج Credentials

به دنبال بسته‌هایی بگردید که شامل "USER" به همراه نام کاربری و "PASS" به همراه رمز عبور باشند. به عنوان مثال:

Username : admin

Password: P@ssw0rd123

این بسته‌ها حاوی اطلاعات ورود هستند که می‌توان آن‌ها را برای دسترسی به سیستم تارگت استفاده کرد.

۴. یادداشت کردن Credentials

نام کاربری و رمز عبور را یادداشت کنید تا بتوانید در مراحل بعدی از آن‌ها برای ورود به سرور FTP استفاده کنید.

یک نکته برای red teamers :

اطمینان حاصل کنید که فرآیند کپچر کردن ترافیک در طول جلسات فعال FTP انجام شود، زیرا Credentials فقط در هنگام ورود (Login) قابل مشاهده هستند و شبکه‌های مدرن ممکن است ترافیک FTP را مسدود یا رمزگذاری کنند.

کپچر کردن ترافیک Telnet

Telnet نیز Credentials را به صورت متنی و بدون رمزگذاری ارسال می کند؛ اگرچه به دلیل مشکلات امنیتی عمدهً منسوخ شده است، هنوز ممکن است در سیستم های قدیمی مشاهده شود.

اثبات مفهوم: استخراج Credentials از ورود Telnet

۱. کپچر کردن ترافیک Telnet

از فیلتر کپچر استفاده کنید tcp port 23: برای کپچر کردن ترافیک Telnet، جایی که درخواست ها و پاسخ های ورود ارسال می شوند.

۲. شناسایی الگوی ورود (Identify Login Sequence)

ورود Telnet معمولاً شامل درخواست های "login:" و "password:" از طرف سرور است، که سپس کاربر ورودی خود را وارد می کند. این ممکن است نیاز به ترکیب چندین بسته برای به دست آوردن ورودی کامل داشته باشد، و برای مشاهده تبادل داده می توانید از گزینه "Follow TCP Stream" در Wireshark استفاده کنید.

۳. استخراج مدارک شناسایی

به دنبال پاسخ کاربر به درخواست ورود و درخواست رمز عبور در جریان باشید، که به صورت متن ساده در بخش "Data" جزئیات بسته قابل مشاهده است.

۴. یادداشت کردن مدارک شناسایی

نام کاربری و رمز عبور را برای استفاده های بعدی ثبت کنید، با این توجه که Telnet در شبکه های مدرن نادر است، اما ممکن است در محیط های جداگانه و سیستم های قدیمی هنوز موجود باشد.

با تجزیه و تحلیل ترافیک شبکه، ردیمرها می‌توانند ساختار شبکه را نقشه‌برداری کنند، از جمله آدرس‌های IP، زیرشبکه‌ها و ارتباطات بین دستگاه‌ها، که یک نقشه برای بهره‌برداری بیشتر فراهم می‌آورد.

تعیین محدوده آدرس‌های IP و زیرشبکه‌ها (Subnets)

شناسایی محدوده آدرس‌های IP مورد استفاده می‌تواند به درک ساختار شبکه کمک کند، از جمله محدوده‌های زیرشبکه و احتمال وجود بخش‌بندی (Segmentation) در شبکه.

اثبات مفهوم: تحلیل آدرس‌های IP برای نقشه‌برداری از زیرشبکه‌ها

۱. گرفتن ترافیک شبکه

ترافیک را بدون استفاده از فیلتر کپچر کنید تا نمای کلی از تمامی IP های درگیر به دست آورید، سپس فایل را با فرمت pcapng ذخیره کنید تا بتوانید بعداً آن را تحلیل کنید.

۲. فهرست کردن آدرس‌های IP منحصربه‌فرد

از مسیر Statistics > Conversations در Wireshark استفاده کنید تا همه آدرس‌های IP فهرست شوند، و بر روی ستون‌های "Address A" و "Address B" تمرکز داشته باشید (برای IPv4 یا IPv6)

یا از ابزار tshark استفاده کنید تا آدرس‌های IP را استخراج کنید، با دستوری مانند:

```
tshark -r file.pcapng -T fields -e ip.src -e ip.dst | sort | uniq
```

این دستور تمام آدرس‌های IP منبع و مقصد منحصربه‌فرد را فهرست می‌کند.

این روش به شما کمک می‌کند تا محدوده‌های زیرشبکه‌ها و الگوهای ارتباطی بین دستگاه‌ها را شناسایی کرده و نقشه‌ای از ساختار شبکه به دست آورید.

۳. شناسایی زیرشبکه‌ها

به دنبال الگوهایی در آدرس‌های IP باشید تا زیرشبکه‌ها را شناسایی کنید. به عنوان مثال، چندین آدرس IP که با 192.168.1.x شروع می‌شوند، نشان‌دهنده زیرشبکه‌ای با آدرس 24/192.168.1.0 هستند. برای تایید این موارد، از ماشین حساب‌های زیرشبکه آنلاین مانند [Subnet Calculator](#) استفاده کنید.

۴. نقشه‌برداری از زیرشبکه‌ها به عملکردها

اگر امکان‌پذیر باشد، عملکرد هر زیرشبکه (مثلاً زیرشبکه سرور، زیرشبکه کاربران و غیره) را با تحلیل نوع ترافیک استنباط کنید. به عنوان مثال، یک زیرشبکه با تعداد زیادی درخواست HTTP ممکن است زیرشبکه وب سرور باشد.

یک نکته برای ردیمرها:

ترافیک را برای یک دوره کافی کیچر کنید تا دید جامعی از شبکه به دست آورید، زیرا کیچرهای کوتاه ممکن است دستگاه‌هایی که به صورت متناوب فعال هستند را از دست بدهند.

تشخیص تجهیزات حیاتی شبکه (IDENTIFYING KEY NETWORK DEVICES)

دستگاه‌هایی مانند روترها و سوئیچ‌ها را می‌توان از طریق رفتارشان در ترافیک شبکه شناسایی کرد، مانند مدیریت چندین آدرس IP یا نقش مرکزی در جریان ترافیک.

اثبات مفهوم: استفاده از ترافیک ARP برای شناسایی زیرساخت شبکه

۱. کیچر کردن ترافیک ARP

از فیلتر گرفتن استفاده کنید arp: تا بر روی درخواست‌ها و پاسخ‌های ARP که آدرس‌های IP را به آدرس‌های MAC نگاشت می‌کنند، تمرکز کنید.

۲. شناسایی پاسخ‌های ARP از روترها و سوئیچ‌ها

روترها اغلب چندین آدرس IP دارند (یکی برای هر اینترفیس) و ممکن است در پاسخ‌های ARP برای زیرشبکه‌های مختلف ظاهر شوند. سوئیچ‌ها ممکن است یک آدرس IP واحد داشته باشند اما در ترافیک ARP برای دستگاه‌های مختلف درگیر باشند، معمولاً با آدرس‌های MAC خاص تولیدکننده (برای مثال، Cisco یا HP).

به فیلدهای "Sender MAC Address" و "Sender IP Address" در پاسخ‌های ARP نگاه کنید تا این دستگاه‌ها را شناسایی کنید.

۳. یادداشت کردن آدرس‌های IP و MAC دستگاه‌ها

آدرس‌های IP و MAC این دستگاه‌ها را برای تحلیل‌های بعدی ثبت کنید، با استفاده از ویژگی Export (خروجی گرفتن) Wireshark یا یادداشت‌های دستی برای ساخت فهرستی از زیرساخت‌های شبکه.

درک جریان ترافیک شبکه برای نقشه‌برداری از ارتباطات

با تحلیل جریان ترافیک، تیم‌های قرمز می‌توانند درک کنند که دستگاه‌ها چگونه به هم متصل هستند، و هاب‌های مرکزی و احتمال وجود بخش‌بندی را شناسایی کنند.

اثبات مفهوم: تجسم ارتباطات شبکه با استفاده از ویژگی‌های Wireshark

۱. استفاده از ویژگی "Statistics > Conversations" در Wireshark

این ویژگی که از مسیر "Statistics > Conversations" قابل دسترسی است، نشان می‌دهد که کدام آدرس‌های IP با یکدیگر ارتباط برقرار می‌کنند و آدرس‌های IP مبدا و مقصد، پورت‌ها و تعداد بسته‌ها را فهرست می‌کند.

۲. تحلیل تبادل داده (Conversations)

گره‌های مرکزی (معمولاً سرورها یا روترها) که با بسیاری از IP های دیگر ارتباط برقرار می‌کنند، و گره‌های حاشیه‌ای (معمولاً کلاینت‌ها) که ارتباطات کمتری دارند را شناسایی کنید. به ستون‌های "Packets" و "Bytes" نگاه کنید تا حجم ترافیک را ارزیابی کنید.

از ویژگی "Follow TCP Stream" یا "Follow UDP Stream" برای مکالمات خاص استفاده کنید تا تعاملات دقیق را مشاهده کنید.

۳. ترسیم نقشه

با توجه به اینکه کدام IP ها به طور مکرر با یکدیگر ارتباط برقرار می‌کنند، توپولوژی شبکه را استنباط کنید. این ارتباطات مکرر می‌تواند نشان‌دهنده اتصالات مستقیم باشد و هر قسمت ایزوله‌شده از شبکه که ترافیک کمی دارد، ممکن است نشان‌دهنده بخش‌بندی باشد.

یک جزئی غیرمنتظره این است که در حالی که Wireshark در نسخه‌های اخیر خود (از اول مارس ۲۰۲۵، دکمه "Map" در نسخه ۲.۶.۰ به دلیل وابستگی به پایگاه‌های داده قدیمی GeoIP حذف شده است) فاقد ویژگی نقشه گرافیکی است، ویژگی "Conversations" یک نمای جدولی فراهم می‌کند که با تفسیر دستی می‌تواند به طور مؤثری ارتباطات را نقشه‌برداری کند.

توماتیک کردن کارها با TShark

در حالی که رابط گرافیکی Wireshark قدرتمند است، تیم‌های قرمز می‌توانند از tshark، نسخه خط فرمان آن، برای خودکارسازی برخی از وظایف استفاده کنند که به افزایش بهره‌وری در شناسایی و جمع‌آوری اطلاعات کمک می‌کند.

مثال: فهرست کردن تمامی آدرس‌های IP منحصربه‌فرد

برای فهرست کردن آدرس‌های IP منحصربه‌فرد در یک فایل capture، از دستور زیر در tshark استفاده کنید:

```
tshark -r capture_file.pcap -T fields -e ip.src -e ip.dst | sort | uniq
```

این دستور به شرح زیر عمل می‌کند:

`-r capture_file.pcap` : فایل capture را بارگذاری می‌کند.

`-T fields` : این گزینه مشخص می‌کند که خروجی به صورت فیلدهای خاص باشد.

`-e ip.src -e ip.dst` : فیلدهای آدرس‌های IP مبدا و مقصد را استخراج می‌کند.

`Sort` : خروجی را مرتب می‌کند.

`Uniq` : فقط آدرس‌های IP منحصربه‌فرد را نمایش می‌دهد.

این روش به تیم‌های قرمز اجازه می‌دهد تا به سرعت آدرس‌های IP فعال در شبکه را شناسایی کنند و آن‌ها را برای تحلیل‌های بیشتر در فرایند شناسایی و نفوذ استفاده کنند.

این دستور تمام آدرس‌های IP مبدا و مقصد را از فایل capture استخراج کرده و آن‌ها را به صورت منحصربه‌فرد فهرست می‌کند، که به شناسایی زیرشبکه‌ها کمک می‌کند.

مثال: استخراج credentials از درخواست‌های HTTP

این دستور tshark برای فیلتر کردن و استخراج داده‌های مربوط به درخواست‌های HTTP POST از فایل capture به کار می‌رود. در ادامه توضیح می‌دهیم که هر قسمت از دستور چه کاری انجام می‌دهد:

```
tshark -r capture_file.pcap -Y "http && http.request.method == \"POST\"" -T fields -e http.http
```

`-r capture_file.pcap`

این بخش فایل capture که داده‌های شبکه در آن ذخیره شده است را مشخص می‌کند. در اینجا `capture_file.pcap` نام فایل است که داده‌های ضبط‌شده را از آن استخراج می‌کند.

`-Y "http && http.request.method == \"POST\""`

این بخش یک فیلتر نمایش می‌دهد که فقط درخواست‌های HTTP با متد POST را نشان می‌دهد.

`http:`

این فیلتر تمام ترافیک HTTP را شامل می‌شود.

`http.request.method == "POST"`

این فیلتر مشخص می‌کند که فقط درخواست‌های با متد POST در نظر گرفته شوند. در واقع این بخش ترافیک مربوط به فرم‌های ارسال شده از کاربر را جدا می‌کند.

-T fields

این گزینه مشخص می‌کند که خروجی به صورت فیلدهای جداگانه (fields) نمایش داده شود. این خروجی شامل مقادیر خاصی است که می‌توان آن‌ها را استخراج کرد.

-e http.http

این بخش مشخص می‌کند که داده‌هایی که از ترافیک HTTP استخراج می‌شوند، شامل فیلدهای مربوط به درخواست HTTP باشند. در اینجا، http.http ممکن است شامل محتویات بدنه درخواست یا سایر داده‌های HTTP باشد.

کاربرد کلی:

این دستور در واقع تمام داده‌های HTTP که متد POST دارند را استخراج کرده و فیلدهای مربوط به آن‌ها (مانند پارامترهای ارسال شده در فرم‌ها) را به نمایش می‌گذارد. این کار معمولاً برای استخراج داده‌های حساس مانند نام‌های کاربری و رمزهای عبور استفاده می‌شود که در بدنه درخواست‌های POST ارسال می‌شوند.

این دستور درخواست‌های HTTP POST را فیلتر کرده و به دنبال خطوطی می‌گردد که حاوی "username" یا "password" باشند، که فرایند استخراج مدارک شناسایی را ساده‌تر می‌کند.

این تنها یک مثال ساده است؛ برای استخراج دقیق و خودکار در پروژه‌های بزرگ‌تر، ممکن است به تجزیه و تحلیل پیچیده‌تری مانند استفاده از Python با pyshark نیاز باشد.

Table: Comparison of Cleartext Protocols for Credential Extraction

Protocol	Port Number	Credential Visibility	Common Use Case	Security Note
HTTP	80	Cleartext in POST/GET	Web login forms, internal apps	Vulnerable, use HTTPS instead
FTP	21	Cleartext USER/PASS	File transfers, legacy systems	Deprecated, use SFTP/FTPS
Telnet	23	Cleartext login/pwd	Remote terminal access, legacy	Highly insecure, use SSH

جدول: مقایسه پروتکل های Cleartext برای استخراج اعتبار

پروتکل	شماره پورت	قابلیت مشاهده اعتبار	مورد استفاده رایج	یادداشت امنیتی
HTTP	80	Cleartext در POST/GET	فرم های ورود به وب، برنامه های داخلی	آسیب پذیر است، به جای آن از HTTPS استفاده کنید
FTP	21	Cleartext USER/PASS	انتقال فایل، سیستم های قدیمی	منسوخ شده، از SFTP/FTPS استفاده کنید
شبکه راه دور	23	Cleartext ورود به سیستم/pwd	دسترسی به ترمینال از راه دور، میراث	بسیار ناامن، از SSH استفاده کنید

این جدول پروتکل ها را نشان می دهد و به تیم های قرمز کمک می کند تا اهداف را بر اساس دیدپذیری و استفاده رایج، برای استخراج credential شناسایی اولویت بندی کنند.

فصل ۴ – تکنیک‌های پیشرفته Red Team با وایرشارک

این فصل با هدف ارائه نمونه‌های عملی و کاربردی (POC) به ردتیمرها یعنی متخصصان امنیتی که فعالیت‌های مهاجم را به صورت شبیه‌سازی شده برای ارزیابی دفاع‌های سازمان انجام می‌دهند تهیه شده است. در این فصل، توانایی‌های پیشرفته Wireshark در سناریوهای واقعی مورد بررسی قرار می‌گیرد.

مطالب این فصل شامل مواردی همچون استخراج داده از نشست‌های SMB، مهندسی معکوس ارتباطات-Command and-Control (C2)، و دور زدن مکانیزم‌های امنیت شبکه با استفاده از بسته‌های تکه‌تکه‌شده (Fragmented Packets) است.

این سناریوها با فرض دسترسی مجاز به شبکه یا سامانه‌ها در فریم ورک قانونی اجرا می‌شوند و بر استفاده اخلاقی و مسئولانه از این تکنیک‌ها تأکید دارند.

استخراج داده از جلسه‌های SMB

پروتکل Server Message Block (SMB) به‌طور گسترده در محیط‌های ویندوز برای اشتراک‌گذاری فایل و دسترسی به منابع شبکه استفاده می‌شود. این موضوع آن را به یک تارگت بزرگ برای اعضای تیم قرمز جهت استخراج اطلاعات ورودی (credentials) یا داده‌های حساس تبدیل می‌کند.

این POC نشان می‌دهد که چگونه می‌توان با استفاده از Wireshark، ترافیک SMB را ضبط و تحلیل کرد و روی استخراج هش‌های NTLM در زمان تنظیم سشن (Session Setup) تمرکز کرد این اطلاعات می‌توانند بعداً برای حملات شکستن رمز (cracking) یا حملات Relay استفاده شوند.

پیش‌نیازها :

❖ نصب نرم‌افزار Wireshark

❖ دسترسی به شبکه‌ای که ترافیک SMB در آن وجود دارد (مثلاً با استفاده از ARP spoofing یا یک

دستگاه مخرب)

❖ ابزارهایی مثل John the Ripper یا Hashcat برای شکستن هش‌های NTLM

اثبات مفهومی: استخراج هش‌های NTLM از ترافیک SMB

۱. کپچر ترافیک SMB

- برنامه Wireshark را اجرا کنید و رابط شبکه مورد نظر را انتخاب کنید (مثلاً eth0)
- یک فیلتر کپچر اعمال کنید port 445: تا فقط ترافیک SMB را (که از پورت TCP 445 استفاده می‌کند) کپچر کنید.
- ضبط را در زمانی شروع کنید که سشن SMB فعال باشد، مثلاً وقتی یک کلاینت به یک پوشه اشتراکی دسترسی پیدا می‌کند، و آن را با نام smb_session.pcap ذخیره کنید .

۲. فیلتر کردن درخواست‌های تنظیم سشن

- فایل smb_session.pcap را در Wireshark باز کنید.
- یک فیلتر نمایشی اعمال کنید `smb2.command == 0x01`: تا فقط درخواست‌های تنظیم سشن SMB2 که شامل اطلاعات احراز هویت هستند نمایش داده شوند.
- در بخش جزئیات پکت (Packet Details Pane)، به دنبال عبارت "NTLMSSP_AUTH" در فیلد "Security Buffer" در لایه SMB2 باشید.

3. استخراج هش‌های NTLM

- بخش "NTLMSSP_AUTH" را گسترش دهید تا فیلدهای زیر را مشاهده کنید:

نام کاربری: مثلاً user123

دامنه: مثلاً DOMAIN

پاسخ: مثلاً NTLMv2: cafebabe12345678...

این مقادیر را می‌توانید به صورت دستی یادداشت کنید یا از قابلیت خروجی‌گیری Wireshark استفاده کنید (File > Export Objects > SMB) در صورتی که فایل‌هایی منتقل شده باشند، اگرچه این راهنمای عملی بر روی اطلاعات احراز هویت تمرکز دارد.

داده‌های استخراج شده را به فرمت فایل هش برای ابزارهای شکستن رمز تبدیل کنید، مثلاً برای ابزار John the Ripper به این شکل:

```
user123::DOMAIN:cafebabe12345678...
```

نکته: هش‌های LM در NTLMv2 اغلب وجود ندارند و با مقادیر جایگزین مانند : AAD3B435B51404EE جایگزین می‌شوند.

۴. شکستن هش‌ها

• از ابزار John the Ripper استفاده کنید:

```
john --format=netntlmv2 smb_hashes.txt
```

با استفاده از یک فهرست واژه (مثلاً rockyou.txt) برای تلاش در بازیابی رمز عبور.

• به‌طور جایگزین، از Hashcat با حالت ۵۶۰۰ استفاده کنید:

```
hashcat -m 5600 -a 0 smb_hashes.txt wordlist.txt
```

5. Red Team Application

• اگر رمز عبور شکسته شد (مثلاً P@ssw0rd123) از آن برای احراز هویت در سایر سیستم‌های شبکه استفاده کنید تا حرکت جانبی در شبکه ممکن شود.

• به‌طور جایگزین، هش NTLM را با استفاده از ابزارهایی مانند Responder یا اسکریپت ntlmrelayx.py از مجموعه Impacket بازپخش (Relay) کنید تا بدون نیاز به شکستن رمز، به سایر سرویس‌های SMB احراز هویت انجام شود، به شرطی که محیط اجازه این بازپخش را بدهد.

ارتباطات (C2) Command-and-Control برای بدافزارها و ایمپلنت‌ها جهت ارتباط با مهاجمان حیاتی هستند. ردتیمر می‌تواند با استفاده از Wireshark ترافیک C2 ابزارهای خود یا بدافزار واقعی را کپچر و مهندسی معکوس کند تا مخفی‌کاری و اثربخشی ایمپلنت‌های خود را بهبود دهد.

پیش‌نیازها

- نصب Wireshark
- یک محیط تست با یک ایمپلنت C2 (مثلاً یک ابزار سفارشی یا ابزار متن‌باز مانند Meterpreter در Metasploit)
- دانش پایه برنامه‌نویسی (مثلاً پایتون برای تحلیل Payload)

اثبات مفهوم (POC): تحلیل و تقلید از ترافیک C2 مبتنی بر HTTP

۱. راه‌اندازی محیط C2

- یک ایمپلنت ساده مبتنی بر HTTP را روی ماشین تست اجرا کنید (مثلاً اسکریپت پایتونی که به صورت دوره‌ای درخواست GET به سرور C2 در آدرس 192.168.1.200:8080 ارسال می‌کند).
- سرور C2 را برای دریافت و پاسخ‌گویی به درخواست‌ها راه‌اندازی کنید.

۲. ضبط ترافیک C2

- در Wireshark ، ترافیک روی رابط شبکه ماشین تست را کپچر کنید، با فیلتر زیر:

```
ip.addr == 192.168.1.200 && tcp.port == 8080
```

- پس از چند دقیقه فعالیت، فایل کپچر شده را با نام c2_traffic.pcap ذخیره کنید.

۳. تحلیل الگوهای ترافیکی

- فایل c2_traffic.pcap را باز کرده و فیلتر نمایش http را اعمال کنید تا فقط ترافیک HTTP را ببینید.
- به موارد زیر توجه کنید:
 - ❖ فرکانس درخواست‌ها (مثلاً هر ۳۰ ثانیه)
 - ❖ اندازه بسته‌ها (مثلاً ۲۰۰ تا ۳۰۰ بایت برای درخواست‌ها و ۱۰۰ بایت برای پاسخ‌ها)
 - ❖ هدرها (مثلاً User-Agent ، Host)
 - ❖ محتوا (مثلاً فرمان‌های رمزگذاری شده مانند cmd=whoami در URL)

برای مشاهده تبادل داده کامل، روی یک بسته کلیک راست کرده و گزینه Follow > TCP Stream را انتخاب کنید. به هرگونه رمزگذاری یا کدگذاری توجه داشته باشید (مثلاً base64).

۴. مهندسی معکوس پروتکل

فرمت Payload را از جریان استخراج کنید، مثلاً:

```
GET /data?cmd=base64encodedcommand
```

Payloadها را به صورت دستی یا با استفاده از اسکریپت پایتون رمزگشایی کنید:

```
import base64
```

```
encoded_cmd = "d2hvYW1p" # Example from capture
```

```
print (base64.b64decode(encoded).decode()) # OutPuts:Whoami
```

```
(decoded_cmd)
```

- فرمت پاسخ سرور را شناسایی کنید، مثلاً خروجی متنی ساده (Plain Text) یا JSON .

5. Red Team Application

ایمپلنت خود را طوری تنظیم کنید که شبیه ترافیک مشروع باشد:

❖ اندازه بسته‌ها و فرکانس ارسال را با ترافیک معمول HTTP (مثلاً مرور یک سایت خبری) مطابقت دهید.

❖ از هدرهای رایج استفاده کنید، مانند: User-Agent: Mozilla/5.0

مجدداً ترافیک را با Wireshark کپچر و تحلیل کنید تا میزان مخفی‌کاری تأیید شود و اطمینان حاصل شود که ترافیک شما با ترافیک عادی ترکیب می‌شود (مثلاً با مقایسه در مسیر: Statistics > Conversations).

دور زدن امنیت شبکه با استفاده از بسته‌های (Fragmented Packets)

دستگاه‌های امنیت شبکه مانند IDS/IPS در صورتی که بسته‌ها را به‌خوبی بازسازی نکنند، غالباً در شناسایی تهدیدهای موجود در ترافیک قطعه‌قطعه (Fragmented) ناکارآمد هستند. این اثبات مفهوم (POC) نشان می‌دهد چگونه می‌توان با استفاده از Wireshark و Scapy، ترافیک مخرب قطعه‌قطعه ساخت و آن را بررسی کرد تا از چنین لایه‌های دفاعی عبور کند.

پیش‌نیازها

❖ نصب Wireshark و Scapy (pip install scapy)

❖ وجود یک شبکه آزمایشی مجهز به IDS/IPS (مثلاً Snort) یا یک محیط تارگت با مجوز تست

اثبات مفهوم (POC): ساخت و بررسی ترافیک مخرب قطعه‌قطعه شده

۱. ساخت ترافیک قطعه‌قطعه‌شده با Scapy

- یک درخواست HTTP مخرب همراه با یک Payload اکسپلویت (Exploit) ایجاد کنید.

```
from scapy.all import *
payload = "GET /exploit?data=malicious_payload HTTP/1.1\r\nHost: target.com\r\n\r\n"
packets = fragment(IP(dst="192.168.1.100")/TCP(dport=80)/payload, fragsize=32)
send(packets)
```

❖ این کار Payload را به قطعات ۳۲ بایتی تقسیم می‌کند، که احتمالاً امضای IDS را بین چندین بسته می‌شکند.

۲. کپچر ترافیک با Wireshark

❖ در اینترفیس ارسال‌کننده بدون فیلتر ترافیک را کپچر کرده و با نام fragmented_exploit.pcap ذخیره کنید.

❖ به‌صورت جایگزین، می‌توانید در شبکه مقصد نیز کپچر را انجام دهید تا دریافت ترافیک را تأیید کنید.

۳. تحلیل بدون بازسازی بسته‌ها (Analyze Without Reassembly)

❖ فایل fragmented_exploit.pcap را در Wireshark باز کنید.

❖ بازسازی را غیرفعال کنید:

Edit > Preferences > Protocols > IPv4 > Uncheck Reassemble fragmented IPv4 datagrams را بردارید.

❖ فیلتر زیر را اعمال کنید: ip.dst == 192.168.1.100 و فیلد "Data" هر قطعه را بررسی کنید اطمینان

حاصل کنید که هیچ قطعه‌ای به‌تنهایی رشته کامل malicious_payload را شامل نمی‌شود، تا احتمال

شناسایی توسط IDS کاهش یابد.

۴. تأیید عملکرد با بازسازی (Verify Functionality with Reassembly)

بازسازی را دوباره فعال کنید و با استفاده از Follow TCP Stream بررسی کنید که کل درخواست HTTP (مثلاً

GET /exploit?data=malicious_payload) به‌درستی و کامل به مقصد رسیده باشد.

از مسیر Statistics > Conversations تعداد و اندازه بسته‌ها را مقایسه کرده و تحویل موفق را تأیید کنید.

5 Red Team Application

از این تکنیک در عملیات واقعی برای ارسال Exploit یا ترافیک C2 به منظور عبور از IDS/IPS استفاده کنید و با بررسی لاگ‌های مقصد یا کیچر ترافیک توسط Wireshark، عدم وجود هشدار را به عنوان نشانه‌ای از عبور موفق تأیید نمایید.

این روش را در محیط آزمایشگاهی روی IDS/IPS خاص (مثلاً Snort) تست کنید تا اندازه بهینه قطعه‌ها را بر اساس توانایی بازسازی آن‌ها تعیین کنید.

Table: Comparison of POC Techniques

Technique	Objective	Wireshark Role	External Tools
SMB Data Extraction	Extract NTLM hashes/files	Traffic capture, protocol decode	John/Hashcat
Reverse Engineering C2	Improve implant stealth	Pattern analysis, payload decode	Python for decoding
Fragmented Packet Bypass	Evade IDS/IPS detection	Verify fragmentation, reassembly	Scapy for crafting

جدول: مقایسه تکنیک‌های POC

تکنیک	هدف	نقش Wireshark	ابزارهای خارجی
استخراج داده‌های SMB	هش/فایل‌های NTLM را استخراج کنید	ضبط ترافیک، رمزگشایی پروتکل	جان/هشکت
مهندسی معکوس C2	بهبود پنهان کاری ایمپلنت	تجزیه و تحلیل الگو، رمزگشایی محموله	پایتون برای رمزگشایی
دور زدن بسته تکه تکه شده	اجتناب از شناسایی IDS/IPS	بررسی تکه تکه شدن، مونتاژ مجدد	Scapy برای صنایع دستی

Table: Comparison of Red Team Techniques in Wireshark

Technique	Objective	Wireshark Role	Example Command/Filter
Credential Extraction (HTTP)	Extract usernames/passwords	Decode HTTP, follow streams	<code>http.request.method == "POST"</code>
NTLM Hash Extraction (SMB)	Extract hashes for cracking	Filter session setup, decode	<code>smb2.command == 0x01</code>
SSL/TLS Decryption	Analyze encrypted traffic	Configure with keys, view data	Edit > Preferences > SSL
Evasion via Fragmentation	Bypass IDS/IPS detection	Disable reassembly, verify	Uncheck "Reassemble IPv4"
C2 Traffic Analysis	Reverse engineer communications	Analyze patterns, decode	<code>ip.addr == 192.168.1.200</code>

جدول: مقایسه تکنیک های تیم قرمز در Wireshark

تکنیک	هدف	نقش Wireshark	فرمان/فیلتر مثال
استخراج اعتبار (HTTP)	استخراج نام کاربری / رمز عبور	HTTP را رمزگشایی کنید، جریان ها را دنبال کنید	<code>http.request.method == "POST"</code>
استخراج هش NTLM (SMB)	استخراج هش برای کرک	تنظیم جلسه فیلتر، رمزگشایی	<code>smb2.command == 0x01</code>
رمزگشایی SSL/TLS	ترافیک رمزگذاری شده را تجزیه و تحلیل کنید	پیکربندی با کلیدها، مشاهده داده ها	ویرایش < تنظیمات > SSL
فرار از طریق تکه تکه شدن	دور زدن شناسایی IDS/IPS	مونتاز مجدد را غیرفعال کنید، تأیید کنید	علامت "Reassemble IPv4" را بردارید
تجزیه و تحلیل ترافیک C2	ارتباطات مهندس معکوس	تجزیه و تحلیل الگوها، رمزگشایی	<code>ip.addr == 192.168.1.200</code>